

Implementación de un Modelo de Seguridad Basado en Zero Trust Network Access (ZTNA) para la Protección de Infraestructuras Empresariales

Proyecto 3er Corte

Smith Oscar Iván Cadena Chitiva
Estudiante
Ingeniería de Telecomunicaciones
Bogotá, Colombia
Politécnico Grancolombiano

Daniela Ruiz Ayala
Estudiante
Ingeniería de Telecomunicaciones
Bogotá, Colombia
Politécnico Grancolombiano

Camilo A. Gutiérrez Rodríguez
Estudiante
Ingeniería de Telecomunicaciones
Bogotá, Colombia
Politécnico Grancolombiano

Abstract – The increasing complexity of cyber threats and the limitations of traditional security approaches have led organizations to seek more robust and adaptable strategies. This paper presents a detailed analysis on the implementation of a security model based on Zero Trust Network Access (ZTNA), designed to mitigate risks by eliminating implicit trust within organizational networks.

Through the application of principles such as constant authentication, role-based access, and network segmentation, the ZTNA model significantly improves the ability of organizations to protect their critical assets. This paper explores the technical aspects, challenges, and advantages associated with adopting this approach, providing practical guidance for its implementation and highlighting its positive impact on business security.

Keywords - Zero Trust Network Access (ZTNA), Cybersecurity, Continuous Authentication, Network Segmentation, Context-Based Access, Identity and Access Management (IAM), Zero Trust Model
Fortinet EMS, Granular Access Control, Critical Resource Protection

Resumen - La creciente complejidad de las amenazas cibernéticas y las limitaciones de los enfoques tradicionales de seguridad han llevado a las organizaciones a buscar estrategias más robustas y adaptables. Este documento presenta un análisis detallado sobre la implementación de un modelo de seguridad basado en Zero Trust Network Access (ZTNA), diseñado para mitigar riesgos al eliminar la confianza implícita dentro de las redes organizacionales.

A través de la aplicación de principios como la autenticación constante, el acceso basado en roles y la segmentación de la red, el modelo ZTNA mejora significativamente la capacidad de las organizaciones para proteger sus activos críticos. Este trabajo explora los aspectos técnicos, los desafíos y las ventajas asociadas con la adopción de este enfoque, proporcionando una guía práctica para su implementación y destacando su impacto positivo en la seguridad empresarial.

Palabras clave - Zero Trust Network Access (ZTNA), Ciberseguridad, Autenticación Continua, Segmentación

de Red, Acceso Basado en Contexto, Gestión de Identidades y Accesos (IAM), Modelo de Confianza Cero Fortinet EMS, Control Granular de Acceso, Protección de Recursos Críticos

I. INTRODUCCION

En un entorno digital cada vez más dinámico y complejo, garantizar la seguridad de los sistemas y redes de una organización representa un desafío continuo. Las amenazas cibernéticas evolucionan constantemente, aprovechándose de las vulnerabilidades existentes y de los métodos tradicionales de protección. En este contexto, los enfoques convencionales, que generalmente confían en la seguridad del perímetro, han demostrado ser insuficientes. Por ello, surge la necesidad de adoptar nuevos paradigmas de seguridad, como el modelo de Zero Trust Network Access (ZTNA), que prioriza la verificación constante, el acceso limitado y el monitoreo continuo. [1,2].

El modelo Zero Trust elimina la confianza implícita dentro de las redes, operando bajo el principio de "nunca confíes, verifica siempre". Este enfoque refuerza la seguridad mediante el control estricto del acceso a los recursos y la segmentación de la red. Este trabajo aborda la implementación de un modelo de seguridad basado en ZTNA dentro de una organización, analizando los componentes fundamentales, los beneficios y las consideraciones clave que aseguran una transición eficaz hacia este marco de seguridad innovador [3,4].

II. MARCO TEORICO

El modelo Zero Trust fue propuesto por John Kindervag en 2010, como una respuesta a las limitaciones de seguridad de los enfoques basados en el perímetro. Este modelo rechaza la idea de un "perímetro confiable" y adopta la premisa de "nunca confiar, siempre verificar." En este contexto, Zero Trust exige que todos los usuarios y dispositivos se autenticquen y autoricen antes de acceder a cualquier

recurso de la red, sin importar si están dentro o fuera de la infraestructura [4]. A diferencia de los enfoques tradicionales que otorgan acceso amplio tras una autenticación inicial, Zero Trust limita el acceso a nivel granular, protegiendo contra amenazas externas e internas y reduciendo el riesgo de movimientos laterales de atacantes [5].

Dentro de la arquitectura Zero Trust, una tecnología clave es el Zero Trust Network Access (ZTNA). A diferencia de las VPN, que otorgan acceso a múltiples recursos de la red una vez autenticado el usuario, ZTNA permite una segmentación mucho más precisa. El acceso a los recursos específicos es permitido solo a aquellos usuarios y dispositivos que cumplen con condiciones predefinidas de seguridad, lo que asegura que incluso si un usuario o dispositivo es autenticado, el acceso se limita exclusivamente a los recursos necesarios para su función [6]. De esta manera, el ZTNA permite no solo una protección mejorada contra intrusiones, sino también una reducción significativa en la posibilidad de que una amenaza interna se propague a través de la red [7].

La implementación de ZTNA generalmente requiere la utilización de herramientas avanzadas como el Endpoint Management Server (EMS) y FortiGate de Fortinet. Estas herramientas permiten gestionar y monitorear los dispositivos y usuarios de manera centralizada, aplicando políticas de seguridad adaptativas y dinámicas. En un entorno ZTNA, EMS gestiona las posturas de seguridad de los dispositivos en tiempo real y comunica con FortiGate para aplicar las políticas de acceso en función del estado de seguridad de cada dispositivo y usuario. Esta integración permite que el acceso a los recursos sea continuo y condicionado, aumentando significativamente la protección contra amenazas en comparación con enfoques tradicionales como las VPN [8].

El modelo Zero Trust es especialmente efectivo en contextos donde los empleados utilizan dispositivos personales o trabajan desde ubicaciones remotas, situaciones que pueden hacer vulnerable la red a ataques como el phishing, *malware* y otros vectores de ataque que comprometen la identidad o la seguridad de un usuario autenticado [9]. A través de políticas de acceso granulares y el monitoreo continuo, ZTNA se adapta a los requisitos de seguridad de las redes empresariales modernas, ofreciendo una solución de acceso que responde a las necesidades cambiantes y cada vez más demandantes de la ciberseguridad [10].

Beneficios de una Red ZTNA

La implementación de ZTNA aporta múltiples beneficios que fortalecen la seguridad en las infraestructuras empresariales modernas:

1. **Seguridad Mejorada:** ZTNA restringe el acceso a recursos específicos según políticas granulares, reduciendo significativamente el riesgo de movimiento lateral y minimizando las superficies de ataque [11].

2. **Adaptación a Modelos de Trabajo Remoto:** Permite un acceso seguro desde cualquier lugar, protegiendo a los usuarios remotos sin necesidad de redes virtuales privadas [12].

3. **Reducción del Impacto de Amenazas Internas:** Al eliminar la confianza implícita, incluso los usuarios internos deben cumplir con estrictos requisitos de autenticación y autorización [13].

4. **Escalabilidad:** Es ideal para empresas en crecimiento que necesitan integrar usuarios y dispositivos adicionales sin comprometer la seguridad de la red.

5. **Control Continuo:** El monitoreo constante de los usuarios y dispositivos asegura que solo aquellos que cumplen con las políticas establecidas puedan mantener su acceso, protegiendo la red ante cambios en el estado de seguridad [14].

Ventajas del Modelo ZTNA

Comparado con otros enfoques de seguridad, ZTNA ofrece varias ventajas clave:

1. **Acceso Granular:** A diferencia de las VPN, que proporcionan acceso amplio a toda la red, ZTNA permite definir qué recursos específicos puede utilizar cada usuario, reduciendo riesgos [15].

2. **Mayor Control sobre Dispositivos:** Incluye evaluaciones continuas del estado de los dispositivos, como la presencia de vulnerabilidades críticas o configuraciones de seguridad activas.

3. **Compatibilidad con la Nube:** Su diseño moderno es ideal para arquitecturas híbridas o completamente basadas en la nube, algo que los métodos tradicionales no pueden abordar eficientemente [16].

4. **Menor Riesgo de Exposición:** Al limitar el acceso únicamente a lo necesario, los atacantes tienen menos oportunidades para explotar vulnerabilidades dentro de la red.

5. **Cumplimiento Normativo:** Facilita el cumplimiento de regulaciones de seguridad y

protección de datos al implementar controles estrictos de acceso [17].

Desventajas de ZTNA

A pesar de sus beneficios, el modelo ZTNA tiene ciertas limitaciones que deben considerarse:

- 1. **Complejidad de Implementación:** La configuración inicial puede ser compleja y requerir experiencia técnica avanzada, especialmente en la integración con sistemas existentes como Directorios Activos [18].
- 2. **Costos Iniciales:** Aunque reduce costos a largo plazo, los recursos necesarios para implementar una solución completa pueden ser significativos.
- 3. **Dependencia de Infraestructura Actualizada:** Requiere herramientas avanzadas de monitoreo y autenticación que no siempre están presentes en todas las organizaciones.
- 4. **Impacto en el Rendimiento:** La verificación continua de usuarios y dispositivos puede generar una ligera latencia en el acceso a recursos, especialmente en redes con alta demanda [19].

Razones para Implementarlo

El modelo ZTNA es especialmente relevante en un contexto donde las amenazas cibernéticas son cada vez más sofisticadas y los entornos de trabajo son más distribuidos. Entre las razones principales para su implementación destacan:

- 1. **Protección Contra Amenazas Internas y Externas:** La eliminación de la confianza implícita asegura que incluso los usuarios internos sean tratados como potenciales amenazas, aumentando la seguridad general [20].
- 2. **Soporte para Trabajo Remoto:** La capacidad de proporcionar un acceso seguro y controlado desde cualquier lugar es esencial para organizaciones con equipos distribuidos.
- 3. **Modernización de Infraestructura:** A medida que las empresas migran a arquitecturas basadas en la nube, ZTNA se convierte en una solución fundamental para garantizar la seguridad en entornos híbridos.

- 4. **Mayor Resiliencia Ante Incidentes:** Limitar el acceso a recursos específicos reduce el impacto de posibles brechas de seguridad [21].

Comparación con Otros Métodos

El modelo ZTNA presenta diferencias clave frente a métodos tradicionales como las VPN o los firewalls perimetrales:

Aspecto	ZTNA	VPN	Firewall Perimetral
Modelo de Seguridad	Basado en acceso granular y continuo	Perímetro confiable	Perímetro confiable
Acceso a Recursos	Limitado y específico	Acceso amplio	Basado en segmentos internos
Escalabilidad	Alta, adecuada para entornos híbridos	Baja, difícil de escalar	Moderada
Protección de la Red	Usuarios internos y externos	Principalmente externos	Principalmente externos
Soporte para la Nube	Nativo	Limitado	Generalmente ausente

Tabla 1. Comparación entre ZTNA, VPN y Firewalls Perimetrales.

Las VPN, aunque útiles en ciertas aplicaciones, presentan desventajas significativas frente a ZTNA. Una vez que un usuario accede a través de una VPN, puede interactuar con toda la red interna, aumentando el riesgo de propagación de amenazas en caso de compromiso. Por otro lado, los firewalls perimetrales, aunque efectivos en la protección del tráfico entrante y saliente, no ofrecen la flexibilidad ni el control granular que ZTNA proporciona [22].

III. OBJETIVO DEL PROYECTO

El objetivo de este proyecto es implementar una solución de ZTNA mediante la tecnología de Fortinet, con el propósito de garantizar un acceso seguro y controlado a los recursos de la red empresarial. A través de la implementación de Fortinet EMS (Endpoint Management Server) y FortiGate, se pretende fortalecer la seguridad mediante la verificación continua de identidad, contexto y estado de dispositivos y usuarios, proporcionando una defensa robusta contra amenazas en comparación con tecnologías tradicionales como las VPN [8]. La configuración y el despliegue de esta arquitectura ZTNA permitirán que las empresas aseguren sus redes contra amenazas internas y externas, mejorando así su capacidad de respuesta ante los desafíos de ciberseguridad contemporáneos [23].

IV. ALCANCE

El proyecto de implementación de Zero Trust Network Access (ZTNA) se realiza en un entorno empresarial controlado, utilizando las soluciones de Fortinet (Endpoint Management Server y FortiGate) para garantizar un acceso seguro y segmentado a los recursos de la red. El alcance se limita a configurar, desplegar y validar una solución de ZTNA que permita el control detallado y dinámico de acceso, protegiendo contra las vulnerabilidades presentes en los enfoques tradicionales como las VPN.

Los objetivos específicos dentro de este alcance incluyen:

1. *Despliegue de Fortinet EMS y FortiGate:*
Implementación de Fortinet EMS para la administración de dispositivos en un entorno local, y configuración de FortiGate como punto de control de acceso en la red.

2. *Integración con Directorio Activo:*
Configuración de un Directorio Activo (Active Directory) con Unidades Organizacionales (OU) para gestionar la autenticación y autorización de usuarios y dispositivos.

3. *Definición de Políticas de Acceso de ZTNA:*
Creación de políticas de acceso segmentadas según el rol y el estado de seguridad de cada dispositivo, asegurando que solo los dispositivos y usuarios autorizados tengan acceso a los recursos específicos.

4. *Pruebas de Acceso Seguro:*
Simulación de conexiones externas para evaluar la efectividad de las políticas ZTNA y la seguridad del acceso a los recursos.

5. *Monitoreo y Evaluación Continua:*
Implementación de herramientas de monitoreo para asegurar la eficacia de las políticas de acceso y realizar ajustes según sea necesario.

Este proyecto se centra exclusivamente en la implementación de ZTNA con la tecnología de Fortinet y en su validación dentro de un entorno controlado.

V. METODOLOGÍA

La metodología de este proyecto es de tipo experimental y secuencial, diseñada para implementar y validar una arquitectura de ZTNA en un entorno empresarial. A continuación, se detallan las etapas de esta metodología:

1. *Análisis de Requerimientos:*

Se realizó un análisis de las necesidades de seguridad y de las vulnerabilidades de la red para definir los parámetros específicos que debe cumplir el modelo

ZTNA, estableciendo condiciones de seguridad para los dispositivos y usuarios.

2. *Instalación y Configuración de EMS y FortiGate:*

Instalación de Fortinet EMS en un entorno local para la gestión de dispositivos y configuración de FortiGate como firewall de red. EMS se utiliza para definir y aplicar políticas de seguridad centralizadas, mientras que FortiGate actúa como punto de control y aplicador de las políticas de acceso bajo el modelo Zero Trust.

3. *Configuración del Directorio Activo (Active Directory):*

Configuración de un Directorio Activo con Unidades Organizacionales (OU) para segmentar a los usuarios según sus roles y aplicar políticas de acceso específicas basadas en la estructura organizacional.

4. *Integración del EMS con el Directorio Activo y FortiGate:*

Integración de EMS con el Directorio Activo para autenticar y gestionar los usuarios bajo el modelo Zero Trust, así como con FortiGate para el control detallado de acceso y aplicación de políticas de seguridad específicas.

5. *Simulación de Conexiones Externas y Validación de Acceso Seguro:*

Pruebas de autenticación y autorización simulando conexiones externas, evaluando la efectividad de las políticas ZTNA implementadas. Esta fase asegura que solo los usuarios y dispositivos que cumplan con los requisitos de seguridad puedan acceder a los recursos necesarios.

6. *Monitoreo y Ajustes Finales:*

Monitoreo del rendimiento de la solución ZTNA mediante herramientas de Fortinet, ajustando configuraciones para asegurar el cumplimiento continuo de las políticas de seguridad y la protección óptima de la red.

Diagrama de la Topología

El diseño incluye dos redes LAN: la del EMS y la de los clientes, protegida por el FortiGate. En esta configuración se encuentran los recursos accesibles a través de políticas ZTNA específicas. Los usuarios externos se conectan mediante Internet, siendo autenticados y autorizados por EMS y FortiGate antes de acceder a los recursos internos.

Servidor

Principal:

El servidor, configurado con **Windows Server 2019**, desempeña múltiples roles esenciales:

- **Active Directory (AD):** Administración de usuarios y dispositivos.
- **DNS Server:** Resolución de nombres en la red interna.
- **Servicios de Acceso Remoto (RDP):** Administración remota del servidor.
- **Fortinet EMS:** Gestión de políticas ZTNA y monitoreo de dispositivos.

Tabla de Redes y Usos

Red	Máscara	Uso
10.10.10.0/29	255.255.255.248	Red para servidores, incluyendo el EMS y su integración con el FortiGate.
192.168.10.0/24	255.255.255.0	Red local para los clientes internos, con direcciones asignadas por DHCP.
192.168.115.0/24	255.255.255.0	NAT para la salida a Internet desde los servidores y clientes internos.

Tabla 1. Tabla de redes y usos

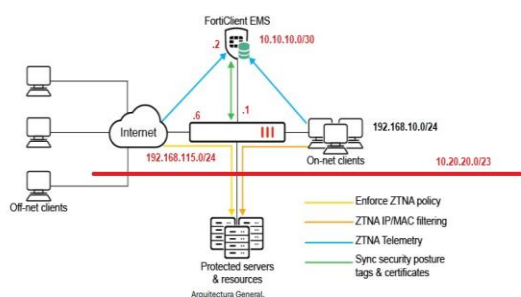


Figura 1. Topología de red para la implementación ZTNA con Fortinet EMS.

Detalles de Conexión

- Clientes fuera de la red (Off-net clients):** Usuarios externos que requieren acceso a recursos protegidos.
- Clientes dentro de la red (On-net clients):** Dispositivos conectados directamente al segmento interno de la red.
- FortiClient EMS:** Gestión centralizada de políticas ZTNA y sincronización de la postura de seguridad con dispositivos.
- FortiGate:** Controlador de acceso que aplica las políticas definidas en EMS.
- Servidores protegidos y recursos:** Activos críticos cuya accesibilidad depende de las políticas ZTNA configuradas.

Flujos Representados en la Imagen

- **En azul:** Telemetría ZTNA entre EMS y los dispositivos conectados.
- **En verde:** Sincronización de etiquetas de postura de seguridad y certificados.
- **En amarillo y naranja:** Aplicación de políticas ZTNA y filtrado basado en direcciones IP/MAC.

Protocolos del EMS

El Fortinet EMS utiliza varios protocolos esenciales que soportan la implementación de ZTNA:

1. TLS/HTTPS (Transport Layer Security):

- Comunicación segura entre EMS y dispositivos administrados.
- Proporciona encriptación para proteger la transmisión de datos sensibles.

2. LDAP (Lightweight Directory Access Protocol):

- Integración con Active Directory para gestionar usuarios y políticas.
- Permite una autenticación centralizada, facilitando la asignación de permisos específicos.

3. ZTNA Connector:

- Función en FortiGate que interactúa con EMS para verificar el estado de seguridad de los dispositivos.
- Evalúa continuamente el contexto y la postura de seguridad antes de otorgar acceso.

4. Syslog:

- Protocolo de monitoreo para generar registros de actividad y auditar eventos.
- Facilita el ajuste de políticas según la información recopilada.

VI.DESARROLLO

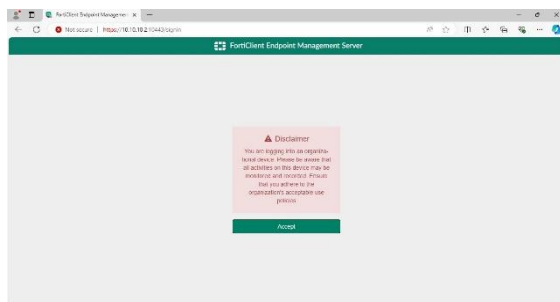
El laboratorio se centra en la implementación de un modelo de seguridad Zero Trust Network Access (ZTNA) para la protección de redes empresariales, utilizando la tecnología de Fortinet. A continuación, se describen los conceptos de los servicios implementados, la topología utilizada y los protocolos relevantes en el sistema.

1. Creación de Máquinas Virtuales

Se desplegaron máquinas virtuales para simular el entorno de laboratorio, utilizando una herramienta

de virtualización como VMware o VirtualBox. Estas máquinas incluyen:

- **Servidor Principal:** Configurado con Windows Server 2019 para alojar Active Directory (AD) y otros servicios críticos.
 - **Clientes:** Dos máquinas con sistemas Windows 10/11 para representar dispositivos finales.
- Las máquinas virtuales se configuraron con las siguientes características principales:
- **Servidor:** 4 GB de RAM, 80 GB de almacenamiento y 2 CPUs.
 - **Clientes:** 2 GB de RAM, 40 GB de almacenamiento y 1 CPU cada uno.



2. Configuración de Firewall:

Habilitar Servicios en el Firewall (ZTNA - Proxy)

En el FortiGate, se activaron los servicios de **ZTNA Proxy**, necesarios para gestionar el acceso basado en políticas de confianza cero. Esto incluye:

- **ZTNA Enforcement:** Controla el acceso a recursos internos según la postura del dispositivo y la identidad del usuario.
- **Proxy:** Actúa como intermediario para las conexiones entrantes y salientes, evaluando continuamente las solicitudes.

El servicio opera en los puertos estándar HTTPS (443) para garantizar una comunicación segura y encriptada.

3. Asignación de Direccionamiento de Red

La red se segmentó en diferentes subredes para facilitar la administración y la seguridad:

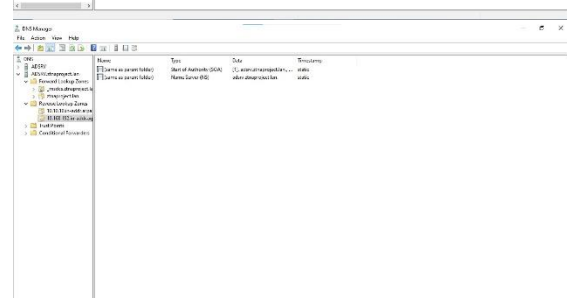
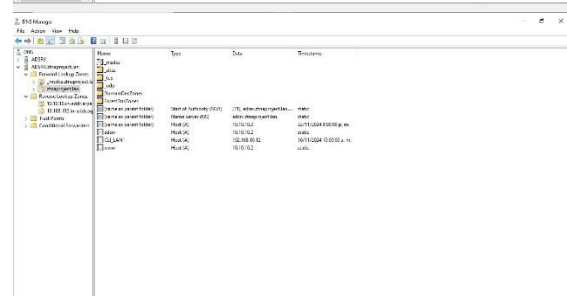
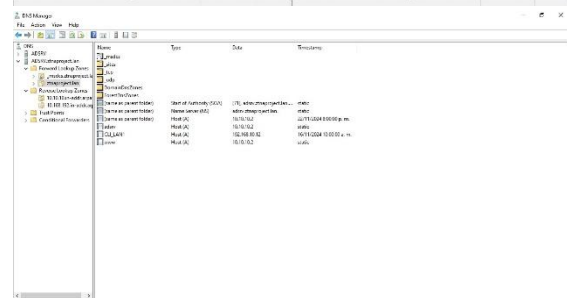
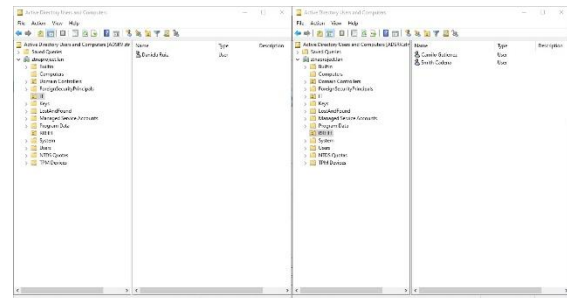
- **Red del Servidor:** Direcciones IP estáticas asignadas manualmente.
- **Red de Clientes:** Configurada con **DHCP** proporcionado por el FortiGate para asignar dinámicamente las direcciones.

Configuración del Firewall para DHCP:

- **Rango de IPs:** 192.168.10.100 - 192.168.10.200
- **Puerta de Enlace:** 192.168.10.1 (IP del Firewall)

- **DNS:** Configuración automática basada en servidores públicos o locales.

Nota: La red del servidor no utiliza DHCP para garantizar mayor control sobre la conectividad y la administración de los servicios críticos.



Servicio SMB (Server Message Block)

Proceso de Instalación y Verificación

1. Instalación del Rol de Archivos y Servicios de Almacenamiento

En Windows Server 2019, se instaló el rol "File and Storage Services" a través del Administrador del Servidor (**Server Manager**):

- Navegar a *Agregar Roles y Características*.
- Seleccionar el rol de *Servicios de Archivos* y habilitar el protocolo **SMB**.
- Finalizar el asistente e instalar los componentes requeridos.

2. Creación de Carpetas Compartidas

- Se creó una carpeta en la ruta: C:\RecursosCompartidos\Documentos.
- Esta carpeta se configuró como compartida mediante el asistente de **Administración de Carpetas Compartidas (Shared Folder Management)**:
- Click derecho sobre la carpeta → *Propiedades* → Pestaña *Compartir*.
- Asignar un nombre de red compartida, por ejemplo: **"Documentos"**.
- Habilitar el acceso para los usuarios autorizados.

3. Permisos Configurados

- **Permisos NTFS**:
- **Administradores del Dominio**: Acceso total (lectura, escritura, modificación).
- **Usuarios Autenticados**: Solo lectura y descarga de archivos.
- **Permisos de Compartición (Share Permissions)**:
- **Grupo de Usuarios Autorizados (AD)**: Control total.
- **Usuarios no autenticados**: Acceso denegado.

4. Verificación del Servicio SMB

- Validación de conectividad desde un cliente:
- Abrir *Explorador de Archivos* en un equipo cliente y conectar a la ruta: \\192.168.10.2\Documentos.
- Probar lectura, escritura y acceso según los permisos configurados.
- Uso del comando en consola:
cmd
Copy code
net view \\192.168.10.2
Esto muestra los recursos compartidos disponibles en el servidor SMB.

Servicio RDP (Remote Desktop Protocol)

Configuración del Acceso Remoto

1. Habilitación del Escritorio Remoto

- En el servidor Windows Server 2019:
- Abrir *Configuración del Sistema*.
- Navegar a *Configuración de Escritorio Remoto* y habilitar **Permitir conexiones remotas a este equipo**.
- Asegurar el uso de autenticación a nivel de red (NLA) para mayor seguridad.

2. Configuración de Usuarios Autorizados

- Solo los miembros del grupo **"Remote Desktop Users"** tienen permisos para acceder remotamente.
- En *Configuración avanzada de sistema* → *Usuarios Remotos*, se agregaron usuarios específicos definidos en el **Active Directory**.

3. Configuración del Firewall

- Habilitar la regla de entrada para **RDP (puerto TCP 3389)** en el firewall de Windows.

4. Verificación del Acceso

- Probar la conexión desde un cliente utilizando la herramienta **Remote Desktop Connection**:
- Dirección IP del servidor: **192.168.10.2**.
- Credenciales de un usuario autorizado.

Configuración del Sitio Web en IIS (Internet Information Services)

1. Instalación del Rol IIS

- A través del *Server Manager*, se instaló el rol **Servidor Web (IIS)**.
- Se seleccionaron los módulos esenciales:
- HTTP y HTTPS.
- ASP.NET 4.5 (si es requerido).
- Registro de Eventos (Logging).

2. Creación del Sitio Web

- Se creó un sitio en IIS con las siguientes características:
- **Ruta física de los archivos web**: C:\inetpub\wwwroot\ProyectoZTNA.
- **Nombre del sitio**: ProyectoZTNA.
- **Puerto de escucha**:
- HTTP: 80.
- HTTPS: 443 (con un certificado SSL configurado).

3. Configuración de Seguridad

- Se instaló un certificado SSL para habilitar HTTPS.
- Se configuraron reglas de acceso para restringir el uso a direcciones IP específicas.
- Se habilitó **autenticación basada en Active Directory** para proteger el acceso a las páginas web.

4. Verificación del Servicio Web

- Se realizó una prueba desde un navegador web accediendo a la URL:
- **http://192.168.10.2:80/ProyectoZTNA**.

- <https://192.168.10.2:443/ProyectoZTNA> (para validar el cifrado SSL).

Creación de Usuario Local

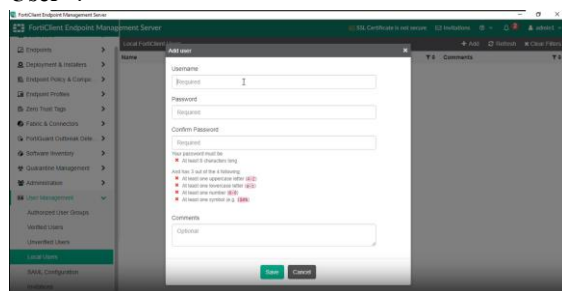
Paso 1: Creación de un Usuario Local

1. Accede al menú "User Management":

En la interfaz de EMS, navega al menú de administración de usuarios y selecciona la pestaña "Local Users".

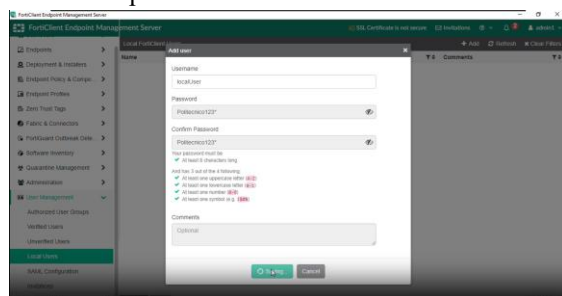
2. Añade un nuevo usuario:

- Haz clic en el botón "+Add" ubicado en la parte superior derecha.
- Aparecerá una ventana emergente titulada "Add User".



3. Configura los datos del usuario:

- **Username:** Ingresa el nombre del usuario, por ejemplo, localUser.
- **Password:** Asigna una contraseña, como Politecnico123*.
- **Confirm Password:** Reingresa la misma contraseña para confirmar.



4. Guarda la configuración:

- Haz clic en el botón "Save" para finalizar la creación del usuario.

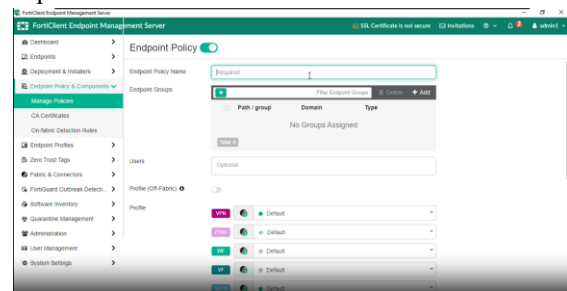
Paso 2: Creación de una Política para el Usuario Local

1. Accede al menú "Endpoint Policy & Components":

Dirígete a esta sección desde el menú principal.

2. Gestiona las políticas:

- Selecciona la opción "Manage Policies".
- Haz clic en el botón "+Add" ubicado en la parte superior derecha.

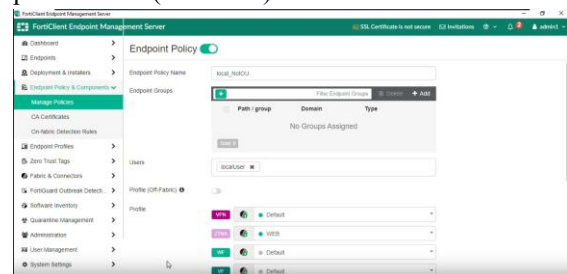


3. Configura la nueva política:

- En el tipo de política, selecciona "Endpoint Policy".
- **Endpoint Policy Name:** Asigna un nombre descriptivo para la política, como local_NotOU.

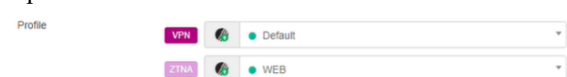
4. Asocia el usuario a la política:

- En la sección Users, selecciona al usuario creado previamente (localUser).



5. Configura el perfil ZTNA:

- Desplázate hasta la sección Profile.
- En el campo ZTNA, selecciona la opción "WEB".



6. Guarda la política:

- Haz clic en el botón "Save" para aplicar la configuración.

Resultado Final:

El usuario localUser estará creado y asociado a una política específica (local_NotOU), que utiliza el perfil ZTNA con enfoque en servicios WEB. Esto garantiza que el usuario local pueda ser autenticado y gestionar el acceso a los recursos protegidos según las configuraciones aplicadas.

4. Instalación de Servicios en el Servidor

En el servidor Windows Server 2019, se instalaron los siguientes servicios:

- **Active Directory (AD):** Para la administración de usuarios, dispositivos y políticas de grupo. AD utiliza el puerto LDAP (389) y el puerto seguro LDAPS (636) para la autenticación.

- **DNS Server:** Configurado para resolver nombres dentro del dominio. El servicio DNS opera en el puerto 53, tcp.

- **Servicios de Acceso Remoto (RDP):** Habilitado para administrar el servidor remotamente. RDP opera en el puerto 3389 para las conexiones de escritorio remoto.

- **Servicio SMB (Server Message Block):** El servicio SMB se implementó para habilitar la compartición de archivos y recursos en red, esencial en entornos colaborativos y empresariales.

Puertos utilizados:

TCP 445: Usado para conexiones modernas y directas sin requerir NetBIOS.

Funciones habilitadas:

- Acceso a carpetas y archivos compartidos desde dispositivos autenticados.
- Gestión centralizada de recursos compartidos, incluyendo impresoras.
- Seguridad mejorada mediante la implementación de **SMB 3.1.1**, que ofrece cifrado de datos y firma de mensajes para garantizar la integridad de las conexiones.
- La configuración incluye la creación de carpetas compartidas protegidas mediante permisos NTFS, asegurando que solo usuarios autorizados puedan acceder a estos recursos. Además, se deshabilitó SMBv1 por razones de seguridad, ya que es una versión obsoleta con vulnerabilidades conocidas.

• Servicio WEB (Internet Information Services, IIS)

El servicio IIS se utilizó para ofrecer capacidades de servidor web, permitiendo la publicación de contenido accesible desde navegadores y la ejecución de aplicaciones web.

Puertos utilizados:

- **TCP 80:** Para tráfico HTTP.
- **TCP 443:** Para tráfico HTTPS con cifrado TLS/SSL.

Configuración implementada:

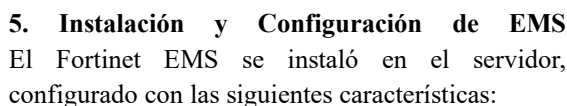
1. Instalación del rol de IIS para habilitar la funcionalidad de servidor web.
2. Configuración de un sitio web predeterminado con soporte para HTTPS.
3. Instalación de un certificado SSL para garantizar la seguridad de las conexiones.

Servicios proporcionados por IIS:

- Hospedaje de aplicaciones web con soporte para tecnologías como **ASP.NET** y **PHP**.
- Gestión centralizada de sitios web y recursos mediante **application pools** para mejorar el rendimiento y la seguridad.
- Registro de tráfico y eventos para facilitar auditorías y análisis.

La configuración de IIS se orientó a garantizar un acceso seguro mediante la implementación de HTTPS y reglas de acceso que limitan la exposición a usuarios no autorizados.

Name	Type	Expiry Date	Assigned To
default_server.crt	Default	2025-11-19 11:30:53 AM	
FTCDMS802401027.2.crt	FortiCare	2026-05-20 03:48:33 PM	
FTCDMS802401027.1.crt	FortiCare	2026-01-19 08:34:59 PM	



- La configuración del EMS permite administrar dispositivos cliente y aplicar políticas ZTNA basadas en la postura del dispositivo.





Active Directory

IP address/hostname

adsrv.zinproject.tan

Port

389

Username

Administrator

Password

LDAPS connection

☐

Alias

Optional

Comment

Optional

Use Connector

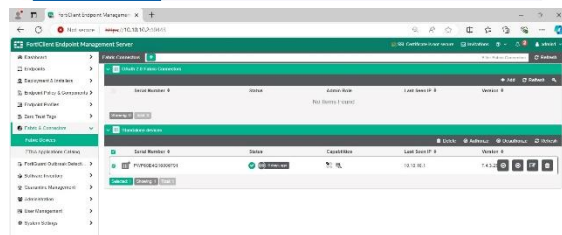
☐

Para sincronizar los usuarios y dispositivos del AD con el EMS, se configuró una conexión LDAP:

- Esta integración permite al EMS aplicar políticas diferenciadas según los roles definidos en el AD.

De forma similar, el FortiGate se integró con el AD para autenticar usuarios en las políticas del firewall:

- **IP del Servidor AD:** 192.168.10.2
- **Puerto LDAP:** 389 o 636.
- **Filtro de Búsqueda:** para identificar usuarios específicos.



Finish

ZTNA Destinations Profile ON

Expand All | Collapse All

Name

Basic
Advanced
XML

General

Allow Personal Destinations ☐

Enforce Valid Server Certificate ☐

Notify user on error ☒

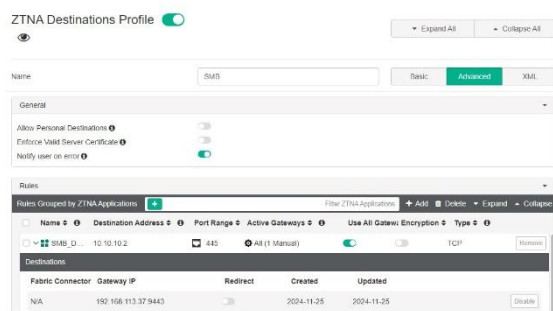
Rules

Rules Grouped by ZTNA Applications +

Filter ZTNA Applications					+ Add	Delete	Expand	Collapse
Name	Destination Address	Port Range	Active Gateways	Use All Gateway Encryption	Type			
☐ INFO [D...]	10.10.10.2		3560	All 1 Manual	☒	[3]	TCP	Remove

Destinations

Fabric Connector	Gateway IP	Redirect	Created	Updated	
N/A	192.168.113.37(5443)		2024-11-25 20:30	2024-11-25 20:38:3	Enable



Add Application

IP Range, CIDR, Subnet Mask, Port List and Port Range are only supported in FortiClient 7.4.1 or later.

Application Type

TCP SaaS

☒ IP ☐ IP Range ☐ FQDN ☐ Wildcard FQDN ☐ CIDR

10.10.10.2

Subnet Mask

255.255.255.255

☐ Any Port ☒ Port ☐ Port List ☐ Port Range

80

192.168.113.37-9443 Add Gateway

Name

HTTP_DESTINATION

Finish

Add Application

IP Range, CIDR, Subnet Mask, Port List and Port Range are only supported in FortiClient 7.4.1 or later.

Application Type

TCP SaaS

☒ IP ☐ IP Range ☐ FQDN ☐ Wildcard FQDN ☐ CIDR

10.10.10.2

Subnet Mask

255.255.255.255

☐ Any Port ☒ Port ☐ Port List ☐ Port Range

80

192.168.113.37-9443 Add Gateway

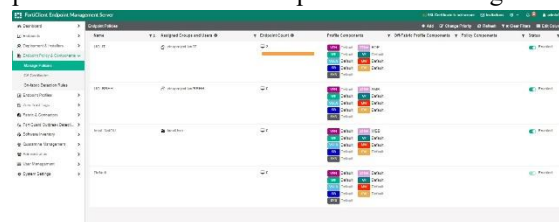
Name

HTTP_DESTINATION

Finish



Seleccionar la Unidad Organizacional y aplicar la política utilizando el filtro previamente configurado.



En el contexto de Fortinet ZTNA (Zero Trust Network Access), la funcionalidad de las etiquetas (tags) depende del caso de uso y la configuración específica. Las etiquetas en ZTNA sirven para clasificar y gestionar dispositivos y usuarios según su contexto y postura de seguridad. Esto permite aplicar políticas más granulares basadas en las necesidades específicas del entorno.

Tipos de ZTNA Tags y Usos

1. **Device Tags:** Identifican dispositivos gestionados en función de sus características o postura de seguridad sincronizadas desde FortiClient EMS. Estas etiquetas suelen incluir detalles como el sistema operativo, nivel de parches, estado de antivirus, entre otros.

2. **User Tags:** Relacionadas con usuarios específicos autenticados mediante FortiGate. Estas etiquetas permiten aplicar políticas según la identidad y el rol del usuario.

3. **Custom Tags:** Configuradas manualmente para abordar casos específicos. Por ejemplo, podrían usarse para etiquetar recursos o segmentar tráfico.

Ejemplo de Configuración de ZTNA con HTTPS Access Proxy

El ZTNA HTTPS Access Proxy de FortiGate actúa como un proxy inverso para servidores HTTP protegidos. El tráfico de los usuarios llega al VIP del proxy en el FortiGate, que autentica al cliente mediante certificados sincronizados desde EMS. Si se utiliza un esquema de autenticación como SAML, los usuarios son redirigidos a un portal de inicio de sesión. Tras la validación, el FortiGate aplica las políticas de acceso configuradas y dirige el tráfico al recurso protegido.

Para configurar ZTNA en este escenario:

1. Configurar FortiClient EMS:

- Sincronizar la postura del dispositivo y definir políticas específicas para aplicar etiquetas relevantes.

2. Crear Políticas de ZTNA en FortiGate:

- Definir reglas basadas en las etiquetas asignadas por EMS.
- Configurar acceso al proxy HTTPS para redirigir el tráfico seguro a los recursos.

3. Verificación y Monitoreo:

- Utilizar el registro de eventos y herramientas como FortiView para confirmar que el tráfico cumple con las políticas de ZTNA configuradas. Este enfoque asegura que solo los usuarios y dispositivos con contexto de seguridad aprobado accedan a los recursos protegidos.

Source	Destination	Action	Status
192.168.1.100	192.168.1.1	HTTPS Proxy	Success
192.168.1.101	192.168.1.1	HTTPS Proxy	Success
192.168.1.102	192.168.1.1	HTTPS Proxy	Success
192.168.1.103	192.168.1.1	HTTPS Proxy	Success
192.168.1.104	192.168.1.1	HTTPS Proxy	Success
192.168.1.105	192.168.1.1	HTTPS Proxy	Success
192.168.1.106	192.168.1.1	HTTPS Proxy	Success
192.168.1.107	192.168.1.1	HTTPS Proxy	Success
192.168.1.108	192.168.1.1	HTTPS Proxy	Success
192.168.1.109	192.168.1.1	HTTPS Proxy	Success
192.168.1.110	192.168.1.1	HTTPS Proxy	Success

Zero Trust Tagging Rule Set

Name: FWDIS_VULCRIT

Tag Endpoint As: FWDIS_VULCRIT

Enabled: ☒

Comments: Optional

Rules: ☒ Edit Rule ☐ Delete Rule

Type	Value
Windows (2)	Critical
Vulnerable Devices Severity Level	Critical
Firewall Threat	SMB_DISABLE

Zero Trust Tagging Rule Set

Name: FWDIS_VULCRIT

Tag Endpoint As: FWDIS_VULCRIT

Enabled: ☒

Comments: Optional

Rules: ☒ Edit Rule ☐ Delete Rule

Type	Value
Windows (2)	Critical
Vulnerable Devices Severity Level	Critical
Firewall Threat	SMB_DISABLE

10. Configuración en EMS

Se definieron las políticas ZTNA:

- **ZTNA Destinations:** Especificación de los servicios habilitados.
- **Políticas de Administración:** Determinación de las reglas según la postura del dispositivo.
- **Posture Tags:** Etiquetas asignadas para dispositivos que cumplen con los criterios de seguridad.

11. Creación de Reglas de Tráfico en el Firewall

Se crearon reglas que especifican:

- **Acceso Permitido:** Según el rol del usuario y la postura del dispositivo.
- **Bloqueos:** Para dispositivos sin antivirus o con firewall deshabilitado.

Explicación de la Topología

La topología de la red diseñada para este laboratorio incluye los siguientes componentes principales:

1. **Fortinet EMS (On-Premises):** Implementado en un servidor local para gestionar dispositivos y aplicar políticas de seguridad de manera centralizada.

2. **Active Directory:** Configurado en un servidor Windows Server, el cual actúa como repositorio de usuarios y dispositivos, permitiendo autenticaciones basadas en roles.

3. **FortiGate (Firewall):** Configurado para interceptar y evaluar todas las solicitudes de acceso a recursos de la red empresarial.

4. **Usuarios y Dispositivos:** Tres perfiles de usuarios representados por:

- Usuario 1: Requiere acceso a RDP sin vulnerabilidades críticas.
- Usuario 2: Necesita acceso a SMB con el firewall habilitado.
- Usuario 3: Usuario local que cumple condiciones combinadas para acceder a un recurso web.

VII. RESULTADOS

VIII. CONCLUSIONES

REFERENCIAS

[1] E. Cole, Network Security Bible, 2nd ed. Indianapolis, IN: Wiley, 2009.

[2] P. Sandhu, "Limitations of VPNs in Modern Security Architectures," Cybersecurity Journal, vol. 12, no. 4, pp. 24-30, 2020.

[3] "Onboarding for ZTNA Deployment Guide," Fortinet, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.0/onboarding-for-ztna-deployment-guide/891466/deployment-overview>.

[4] J. Kindervag, "Build Security Into Your Network's DNA: The Zero Trust Network Architecture," Forrester Research, 2010.

- [5] L. Chen y X. Wang, "A Survey of Zero Trust Architecture in Cybersecurity," *Journal of Information Security and Applications*, vol. 45, pp. 45-55, 2020.
- [6] F. Martinez y A. Sanchez, *Fundamentals of Zero Trust Networks*, 1st ed. New York, NY: Springer, 2021.
- [7] G. R. Sinha, "ZTNA as a Superior Solution to VPNs in Enterprise Security," *International Journal of Cybersecurity Solutions*, vol. 3, no. 2, pp. 15-23, 2021.
- [8] Fortinet, *Getting Started with EMS*, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.5/ems-administration-guide/385506>.
- [9] R. Anderson, *Zero Trust and Endpoint Security: Advanced Strategies for the Modern Enterprise*, 1st ed. Boston, MA: McGraw-Hill, 2022.
- [10] "EMS Administration Guide," Fortinet, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.5/ems-administration-guide/24450/introduction>
- [11] F. Martinez y A. Sanchez, *Fundamentals of Zero Trust Networks*, 1st ed. New York, NY: Springer, 2021.
- [12] P. Sandhu, "Limitations of VPNs in Modern Security Architectures," *Cybersecurity Journal*, vol. 12, no. 4, pp. 24-30, 2020.
- [13] D. Lopez, "Adaptative Security through Zero Trust: An In-depth Analysis," *Information Systems Security Journal*, vol. 11, no. 3, pp. 34-42, 2021.
- [14] Fortinet, *Getting Started with EMS*, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.5/ems-administration-guide/385506>.
- [15] R. Anderson, *Zero Trust and Endpoint Security: Advanced Strategies for the Modern Enterprise*, 1st ed. Boston, MA: McGraw-Hill, 2022.
- [16] G. R. Sinha, "ZTNA as a Superior Solution to VPNs in Enterprise Security," *International Journal of Cybersecurity Solutions*, vol. 3, no. 2, pp. 15-23, 2021.
- [17] D. Geer y S. Raju, "Trust No One: Evolving Network Security Beyond VPNs with Zero Trust," *IEEE Security & Privacy*, vol. 19, no. 3, pp. 38-46, 2021.
- [19] "EMS Administration Guide," Fortinet, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.5/ems-administration-guide/24450/introduction>.
- [20] "Onboarding for ZTNA Deployment Guide," Fortinet, 2023. [Online]. Available: <https://docs.fortinet.com/document/forticlient/7.2.0/onboarding-for-ztna-deployment-guide/891466/deployment-overview>.
- [21] N. Davis, *Zero Trust Security: Architecture and Best Practices*, 1st ed. Hoboken, NJ: Wiley, 2021.
- [22] J. White, "Comparing VPN and ZTNA: Evolution of Secure Access," *Cybersecurity Insights*, vol. 8, no. 3, pp. 19-27, 2021.
- [23] S. Kumar y R. Gupta, "Beyond Firewalls: Transitioning to Zero Trust Network Access," *Journal of Advanced Network Security*, vol. 14, no. 2, pp. 44-56, 2022.